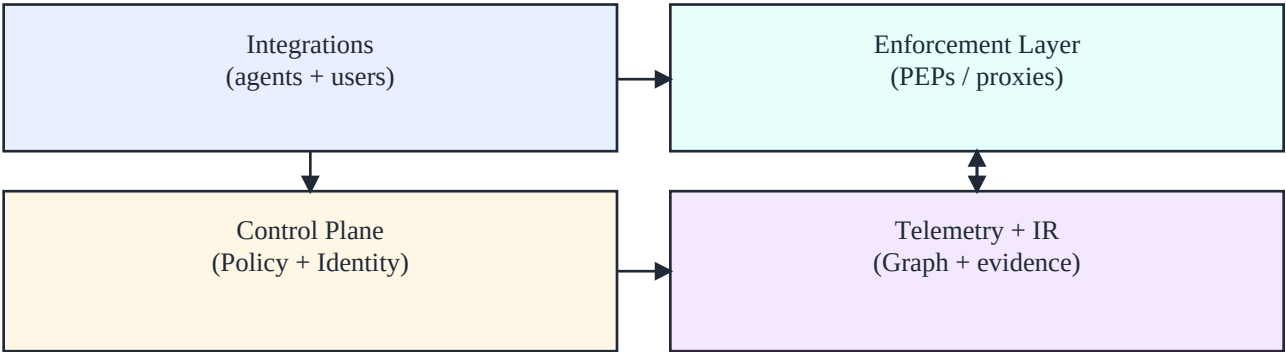


Agent Mesh Observatory & Governor

Market & Competitive Analysis (Pivot: Shadow AI Control Plane)

Last updated: Dec 25, 2025

Thesis: "shadow AI" is not just a visibility problem. The real gap is enforceable control at the moment of action (prompt -> data egress / tool call -> real-world side effects), across BOTH ad-hoc employees and production agents.



Core idea: route all AI interactions through enforceable policy and produce incident-grade evidence.

1. Executive summary

Organizations have two different (and currently disconnected) problems: (1) employees using unapproved GenAI tools via web/desktop/IDE ('shadow AI'), and (2) sanctioned internal agents that increasingly have tool access and operational blast radius. Most vendors solve one side, not both.

- **Market gap:** a unified *AI access broker* that routes all GenAI usage through policy + identity, and can enforce least privilege for tool-enabled agents (PDP/PEP) with incident-grade evidence.
- **Wedge:** stop data leakage and risky actions without banning tools: route, redact, approve, and audit.
- **Positioning:** the "SSE/CASB for AI actions" + the "control plane for agent tool calls" (one policy model).

Why now

- GenAI adoption is already broad; policies are lagging and employees bypass them for speed.
- Agent platforms are productizing "tool access" and "runtime" - but the enterprise still needs cross-vendor controls and forensics.
- Security teams are being asked to answer: "who used what AI, with what data, and what actions did it trigger?"

2. The real problem to fix

Most 'shadow AI' programs start with discovery (network/SaaS visibility) and end with training and policy docs. But the highest-risk failures happen **mid-flight**: a user pastes proprietary code into a consumer model, or an agent uses a privileged connector (SQL, tickets, cloud APIs) after prompt injection. The unmet need is enforceable, explainable control where the interaction crosses a trust boundary.

Problem decomposition

- **Identity**: bind every AI interaction to a human or service identity (SSO, device, workload identity).
- **Routing**: force all GenAI requests (web, API, IDE) through an approved gateway or proxy.
- **Data boundary**: classify + redact sensitive content at the edge; block or require approval for high-risk classes.
- **Action boundary**: for tool-enabled agents, enforce capability-based authorization on tool calls (constraints, approvals, time-bounded grants).
- **Evidence**: produce an incident timeline + exportable evidence bundle (what, when, who, which policy, why).

What 'good' looks like

- A platform team can answer "show me all AI usage involving Repo X or Customer Y" in minutes, not days.
- An AppSec team can set one rule and it applies to browser use, IDE copilots, and internal agents.
- When something goes wrong, the system produces a complete evidence bundle without scraping logs by hand.

3. Buyer + user personas

- **Primary buyer:** Head of Security (SSE/SASE), Head of IT/SaaS Management, Head of Platform/AI Platform.
- **Primary users:** SecOps/IR, AppSec, IT/SaaS admins, AI platform engineers, data governance owners.
- **Design partners:** companies with both: (a) widespread employee GenAI usage and (b) internal agents with connectors.

Primary value props

- Reduce data leakage risk without killing productivity.
- Centralized controls for tool access that scale across teams and frameworks.
- Shorten investigation time and improve audit readiness with evidence exports.
- Cost control via routing, budgets, and guardrails (rate limits, kill switches).

4. Competitive landscape

This space is converging. The winning wedge must be crisp and enforceable.

Category	What they do well	Typical gap vs this pivot
SSE/CASB + SaaS mgmt	Discover shadow tools, manage SaaS risk	Limited AI-native enforcement at prompt/tool boundary; weak agent tool governance
AI gateways / agent mesh	Routing, protocol support, governance language	Often network-centric; weaker identity/evidence UX; limited end-user shadow AI coverage
Agent platforms (cloud)	Managed runtimes, tool gateways, monitoring	Cloud-locked; doesn't cover unsanctioned usage; customers still need cross-vendor policy + IR
LLM observability	Tracing, evals, cost + latency dashboards	Typically observe/alert, not enforce; focus on sanctioned apps, not shadow usage
AI governance platforms	Policy, eval, compliance narratives	Less operational control-plane depth; weaker real-time enforcement

Key competitive reality

- Crowded at the edges (visibility, dashboards). Less crowded at the **action boundary** (enforceable control + evidence) across both users and agents.
- Cloud agent platforms will win "agents on that cloud". Cross-vendor + shadow AI coverage remains a gap.
- Network/security incumbents can extend into AI; wedge must deliver time-to-value in days, not quarters.

5. Differentiation and wedge strategy

A winning wedge must be **operationally enforceable**, not just reporting.

- **Unified policy model:** same primitives for 'employee prompt upload' and 'agent tool call' (identity, resource, action, parameters, environment, time).
- **Capability-based tool access:** mint short-lived, scoped credentials per tool call (break-glass approvals, row/field constraints).
- **Intent receipts:** every allowed action returns a machine-readable receipt (decision + constraints + rationale codes) stored for IR.
- **Safe-by-default privacy:** store hashes/summaries by default; raw content optional and customer-controlled.

Go-to-market sequencing (recommended)

- **Step 1:** browser/IDE visibility + routing (approved gateway) for 'shadow AI' - immediate buyer pain.
- **Step 2:** enforce data boundary controls (classification/redaction/approvals).
- **Step 3:** extend the same plane to internal agents (SDK/proxy PEPs + PDP).
- **Step 4:** IR workflows: evidence bundles, incident timelines, forensics exports.

6. 'If AWS AgentCore exists, what's the point?'

AgentCore (and similar) is a strong managed runtime and tool gateway. It does not eliminate the need for a cross-vendor control plane that also covers unsanctioned employee usage. The wedge is: one policy/evidence system across **all** AI interactions, not only Bedrock-hosted agents.

- Coverage: employee web/desktop/IDE usage + agents across multiple frameworks/providers.
- Independence: works even when teams mix clouds, models, and runtimes.
- Depth: credential brokering + constrained tool execution + audit-grade evidence bundles.